Orbis Pay est une entreprise fictive. Vidéo de démo : `docs/video/sAIfe-demo.mp4`.

La menace. Un contenu piégé vise deux lecteurs. Le salarié clique un lien trompeur, ouvre un site sosie ou valide un virement réclamé par un faux dirigeant. L'agent IA interne lit un mail qui cache une consigne, la prend pour une tâche et tente d'envoyer des données dehors avec ses propres droits. sAIfe suit les deux chemins jusqu'au même dossier SOC, où un humain décide. Hors sAIfe : 33,1 % des salariés non formés échouent aux tests de phishing simulés (KnowBe4 2025) ; EchoLeak, CVE-2025-32711, fuite par Microsoft 365 Copilot sans clic (The Hacker News) ; injection via le serveur MCP de GitHub, mai 2025 (Invariant Labs).

Les contrôles

- Poste : l'app Mac prévient avant le geste (mail frauduleux, site louche, fichier à risque) et tient l'inventaire des agents IA du poste ; l'extension Chrome arrête un site sosie ou louche, avec les mêmes règles. Le salarié choisit ; le poste n'est jamais bloqué ni verrouillé. Quatre modules qu'on peut couper ; au SOC partent la catégorie, le domaine et le choix. Pour un mail jugé frauduleux, une copie désarmée part du serveur de messagerie ; sinon, jamais le contenu d'un fichier ni la valeur d'un secret.
- Geste critique (virement, export de clients) : l'app du poste le déclare à sAIfe (appel local `/avertir`, ou geste repéré dans un mail), des règles y cherchent un signal avant de laisser le salarié continuer ; rien ne s'interpose dans le vrai flux de paiement, ce branchement est une étape de déploiement. Sans signal, il part sans pop-up. Signal sans fraude (RIB qui change, bénéficiaire inconnu) : retenu, le responsable ou la finance le tranche dans l'espace `/validation`. Signal de fraude : relecteur IA et incident SOC.
- Garde-mail : chaque mail est jugé sûr, suspect ou frauduleux, avec une phrase par signal.
- Passerelle de l'agent : désarmeur des consignes cachées avant lecture, jeton limité à la tâche, canaris, envoi hors d'Orbis Pay retenu. Médiation de tous les outils : outil absent de l'inventaire, outil de lecture détourné (paramètres décodés en URL, base64, hexadécimal), outil MCP modifié en cours de session, retenus avant exécution, pour 0,07 ms de plus en médiane.
- Journal chaîné en SHA-256, signé en Ed25519 par le backend (une clé locale par canal d'origine), en ajout seul ; `/verification` nomme le champ modifié. Qui n'a que la base ne peut pas la réécrire sans que ça se voie ; qui tient la machine, oui. Rapport d'une page pour le RSSI. Ancrage sur Avalanche : voie d'exploration, aucune ancre publiée.
- Intégrations : ECS 8.11, CEF par syslog, 29 règles Sigma validées par sigma-cli, webhooks Slack et Teams, SMS simulé, résumé du lundi, brouillon NIS2 à relire. Quatre identités authentifiées : analyste, passerelle, poste, validateur.

Comment l'humain garde la main

- Le salarié est prévenu avant d'agir, avec la raison, et choisit. « Annuler » compte un piège évité, sans ouvrir de dossier.
- Relecteur IA (Claude Haiku, d'Anthropic) : il reçoit des faits établis par sAIfe, jamais le mail. Les règles dures passent avant lui (plafond de 10 000 € hors liste, RIB qui change, consigne cachée, rafale) ; panne ou délai de plus de 8 s, les règles tranchent et retiennent dans le doute. Sur un signal de fraude, rien n'est accordé en silence. Sa mémoire ne reçoit que des décisions humaines signées. L'analyste garde « Accorder » et « Refuser », motif scellé.
- Le responsable ou la finance voit le montant, le bénéficiaire et la raison, et décide avec un motif signé ; la sécurité n'apprend que l'issue.
- Besoin d'en connaître : le SOC lit des tranches de montant, bénéficiaires et IBAN masqués, salariés sous pseudonyme. Le détail s'ouvre sur un signal de fraude, et chaque consultation entre au journal.
- Agent : « Couper » demande confirmation, motif et cinq secondes pour annuler ; sans décision, l'appel retenu est refusé.
- Règles en français : chaque phrase lance un agent jetable (six outils qui n'écrivent pas, 20 s, jeton révoqué à la fin). sAIfe montre ce qu'il a compris et ce qu'il n'a pas su traduire, et n'active rien sans clic. Le retrait des droits en trop est réel.
- Seuils : session classée agent IA au-dessus de 0,40 ; canari, envoi externe ou outil inconnu, l'agent est suspendu ; droit retiré, tentative bloquée et incident ; comportement inhabituel, simple alerte.

Ce qu'on a mesuré

Le 11 octobre 2026 à 9 h 35, commit `fb6fa41`, sur des backends isolés. Trafic et mails écrits pour la démo ; les durées sont celles de la chaîne technique sur le banc, pas une cadence d'attaque.

- Agent interne piégé, vraie passerelle : 25/25 sessions classées agent IA, 25/25 incidents, 0 rapport sorti. Détection : médiane 12 ms, moyenne 17 ms. Confinement : médiane 32 ms, moyenne 31 ms, coupure envoyée par script. 25 échantillons chacun.
- Agent IA externe : 25/25 incidents. Faux positifs : 0/50 sessions humaines ou scriptées classées agent IA.
- 12 mails de démo : 8/8 frauduleux repérés, 0/3 légitime signalé, le douteux classé « suspect ». Désarmeur : consigne retirée dans 2/2 mails qui en portent une, 0/10 ailleurs.
- Relecteur IA, 6 gestes critiques : 4 refusés d'office par les règles dures (modèle non appelé), 2 relus par Haiku (1 accordé, 1 retenu) en 4,0 s et 4,8 s.
- Mode réel, 11 octobre : Haiku pilote l'agent sur de vrais services locaux et a résisté à l'injection (0/3, puis 0/5). Un attaquant déterministe sur les mêmes services : mail livré sans sAIfe, retenu avec.

Non mesuré : le temps de décision d'un analyste ou d'un responsable, un vrai poste.

Tests

926 tests réussis le 11 octobre 2026 à 8 h 55, commit `cb8b6bc` : backend 522, interne 205, messagerie 73, attaque 29, poste 17, ancienne surface externe 19, scripts de démo 35, extension 26. Hors tests Swift de l'app Mac. Ils vérifient le prototype, pas une détection en production.

Limites

Trafic et mails écrits pour la démo, entreprise fictive : ces chiffres montrent la cohérence du moteur, pas une détection en production. Désarmeur, analyseur de mails et extension reposent sur des motifs : une consigne paraphrasée et polie peut passer, d'où le contrôle de l'action. Le relecteur reste attaquable comme tout modèle. Pas de branchement sur Outlook ou Gmail ; volet poste sur macOS et Chrome seulement. Un jeton par rôle, pas par personne ; SQLite et un seul écrivain. Prévu avant un déploiement : purge à 90 jours, analyse d'impact, information des salariés et du CSE, relecteur sur un modèle hébergé dans l'UE ou en mode règles. Brouillon NIS2 et correspondances jamais audités.

Feuille de route

Demandé par les testeurs (des personas joués par des agents, pas de vraies personnes), pas fait pour le 11 octobre : app Windows, Microsoft 365 (Outlook, Exchange), SSO (OIDC) avec les rôles de l'annuaire. Ensuite : ancrage Avalanche, SMS et résumé réellement envoyés, connecteurs Sentinel et Splunk.

Correspondances (repères, pas une certification)

OWASP Agentic ASI01 (détournement d'objectif), ASI02 (usage abusif des outils), ASI03 (abus d'identité et de privilèges) ; MITRE ATLAS AML.T0051.001, T0053, T0057 ; ATT&CK T1566 phishing, T1657 virement frauduleux, T1048, T1555 dans les règles Sigma ; NIST CSF 2.0 DE.CM-09, DE.AE-02, DE.AE-08, RS.MA-02, RS.AN-03, RS.MI-01 ; NIS2 art. 23 : sAIfe prépare le brouillon d'alerte sous 24 h, l'humain qualifie et notifie.

Cible, modèle, équipe

Entreprises régulées (finance sous DORA, santé), 500 à 5 000 salariés, avec un SOC et au moins un agent IA en production ou en pilote. Le RSSI achète, l'analyste SOC utilise, le responsable métier confirme les gestes retenus, le DPO valide, le CSE est consulté pour le poste. Licence annuelle par agent supervisé, poste en option, pilote de 3 mois, pas de prix : hypothèses à tester en dix entretiens de RSSI, aucun client. Équipe : Guilhem (agents IA et technique), Paul (mails et business).